

How would a small SaaS company protect customer trust?

An ISO/IEC 27001 implementation-planning case study for a fictional cloud software company.

25 people. Enterprise customers. Security questions that need evidence.

Customer tickets, cloud services, source code, staff access and suppliers all sit inside the proposed security scope.

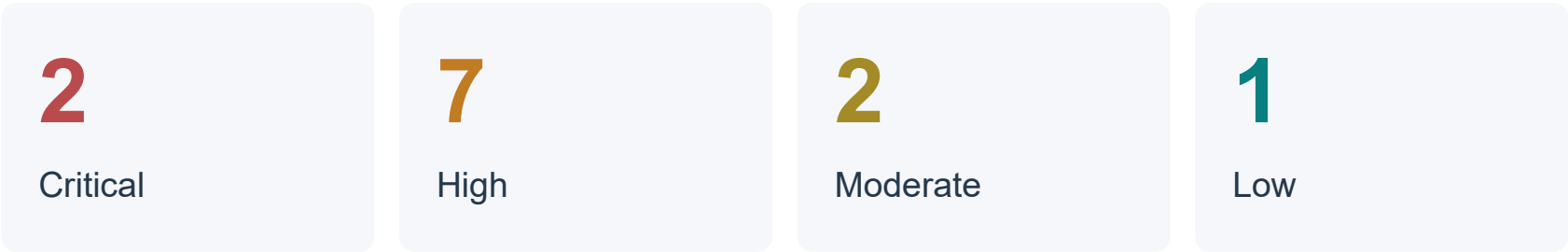
THE WORK

Define the scope. Assess the risks. Choose treatments. Review evidence.

Focused planning + one synthetic access-review cycle

Explain the rating before recommending the fix.

10 assets and 12 risk scenarios, with named owners and a consistent qualitative method.



EXAMPLE / R01

A departed employee still has access to customer tickets.

Likelihood 4 x Impact 4 = 16 / High

A missed leaver record supports the exposure judgment. Ticket disclosure explains the business impact.

This 5-by-5 matrix is a case-study choice. The scores are judgments, not measured probabilities.

Connect each action to a risk and the evidence it needs.

The Statement of Applicability extract covers 21 selected controls. Omitted controls have not been assessed.

Access lifecycle

R01 / A.5.18 + A.6.5

Reconcile employment changes with permissions. Keep approvals, revocation records and repeat-review evidence.

Privileged permissions

R02 / A.8.2

Remove unnecessary administration. Retain justified privilege with independent approval and monitoring.

Recoverable backups

R05 / A.8.13 + A.5.30

Restore and validate data against recovery targets. A scheduled backup success is not a restore test.

Risk targets remain conditional until treatments work and the appropriate risk owner accepts the result.

Three corrections. One justified administrator retained.

Reviewed all 27 supplied human access assignments across three fictional systems.

Departed employee

Enabled account -> disabled

AR027 / CA01

Unjustified repository admin

Administrator -> Developer

AR004 / CA02

Sales role mismatch

Agent -> Viewer

AR024 / CA03

Approved cloud administrator

Administrator -> retained

AR011 / AP011

Verified in revised synthetic records. No live account was changed.

A corrected account is the start of a better process.

Immediate corrections and systemic corrective actions need separate evidence.

01 Fix the account, then address the cause.

The sample changes are verified. Recurring leaver and role-change processes still need implementation and effectiveness checks.

02 Keep remaining risk visible.

Three risks remain High even at their proposed target ratings. Management still has decisions to make.

03 State the limits clearly.

This is an educational simulation with a partial SoA. It does not establish a fully implemented ISMS or certification.

NEXT LEARNING STEP

Build an internal audit simulation.